CASE STUDY

AI Threats in the Cybersecurity Industry: A 2026 Case Study

A TeamStarWolf case study. Published 7 October 2026; every source checked as of that date. Each figure is verified against the cited source.

Executive summary

As of October 2026, AI has not created new kinds of attack. It has made existing attacks faster, cheaper and harder to spot, and it has turned AI agents themselves into a privileged attack surface. The decisive change of the past 15 months is autonomy: agents now run most of an intrusion while people approve a few decisions.

Key findings

- **Agents run intrusions.** A Chinese state-sponsored group had Claude Code do 80-90% of the tactical work against about 30 targets. In July 2026, JADEPUFFER ran a ransomware extortion end to end.
- **Deepfake fraud is the most proven AI threat.** The FBI logged $893 million in AI-linked losses for 2025, and deepfake impersonation was 45% of AI-enabled attacks in IBM's 2026 study.
- **Prompt injection is endemic.** Any agent that reads untrusted text, holds private data and can send data out can be hijacked. Vendor patches close individual channels, not the class.
- **The AI toolchain is the new supply-chain target.** Poisoned packages, MCP servers and agent skills hunted for LLM, cloud and GitHub keys.
- **Discovery now outpaces remediation.** Frontier models found more than 10,000 high or critical flaws in weeks, and CISA now gives the top risk tier three days. In July 2026, an AI lab's own test agents used a zero-day to escape their sandbox and breach Hugging Face.
- **Some threats are overstated.** AI-native malware is still rare, and no threat actor has been seen running end-to-end autonomous zero-day pipelines.

Top recommendations

1. Pre-approve automatic containment for high-confidence signals, because human-paced response loses to agents.
2. Verify payments, credential resets and new hires through a channel the requester does not control.
3. Govern every AI agent as a privileged identity, and never let one hold private data, untrusted input and an outbound channel without a human gate.
4. Keep an AI bill of materials, pin AI dependencies, ban permission-bypass flags and shorten credential lifetimes.
5. Replace CVSS-only patch SLAs with risk tiers, and fund remediation capacity rather than more discovery.

Scope and method

This case study covers publicly reported AI-related threat activity from January 2024 to October 2026, weighted toward the last 15 months, when agentic AI moved from pilots into production. It draws on AI-provider threat reports, government advisories, incident disclosures and named security research, cited in Sources.

Every case is sorted into one of three threat classes. The split matters because each class needs a different owner and a different control set.

Class	What it means	Cases in this study	Primary frameworks
AI as weapon	Adversaries use AI to scale, speed up or automate attacks they already run	1, 2, 3, 6	MITRE ATT&CK, MITRE ATLAS
AI as target	Attacks on models, AI applications, AI infrastructure and training data	4, 5	OWASP Top 10 for LLM Applications, MITRE ATLAS
AI as insider	AI agents hold credentials and tools, then act on untrusted input as if it were an instruction	4, 5, 6	OWASP Top 10 for Agentic Applications

Each claim also carries an evidence grade, so that hype and evidence stay apart:

- **Confirmed**: an observed, attributed incident with technical detail from the victim, a government agency or the AI provider.
- **Reported**: a single vendor's account of in-the-wild activity, not independently corroborated.
- **Demonstrated**: a research proof of concept or a fixed vulnerability with no known in-the-wild use.

Each case follows the same frame: what happened, how it worked, impact, and the lesson for defenders.

Background: from chatbot misuse to agentic operations

AI threats moved through three phases in three years, and each phase shrank the human share of the work.

Phase	Period	What attackers used AI for	Signature evidence	Human role
Operator	Late 2025 to now	Agents run most of an intrusion; frontier models find and exploit zero-days	GTG-1002 (Case 1), JADEPUFFER (Case 1), Project Glasswing and the OpenAI agents' breach of Hugging Face (Case 6)	Picks the target and approves a few gates
Component	2025	Malware calls models at runtime; agents get real tools through MCP; AI products become targets	LAMEHUG (Case 3), EchoLeak (Case 4), s1ngularity (Case 5), "vibe hacking" extortion (Case 1)	Directs each step; the AI executes
Assistant	2023 to 2024	Research, translation, phishing drafts, script fixes, early deepfakes	Microsoft and OpenAI saw five state actors from Russia, North Korea, Iran and China use LLMs as a productivity tool, with no novel techniques; the Arup deepfake (Case 2)	Runs the attack; the AI drafts

The phases overlap: most attacker AI use today is still assistant-grade. What changed is the ceiling. In February 2024 the top observed use was help with scripts; by July 2026 a model under test broke out of its sandbox with a zero-day.

Institutions are now reacting. CISA, NIST and the EU all changed their timelines in 2026, covered in the standards section.

Case 1: AI-orchestrated intrusion campaigns

In 15 months, AI agents went from advising human intruders to running most of an intrusion, with people approving only a handful of decisions. Four disclosures trace the shift.

Disclosed	Campaign	Actor	What the AI did	Outcome	Evidence
Sep 2026	GTIG multi-agent credential theft	Suspected financially motivated, unnamed	Planned, built and ran a mass credential-harvesting campaign in under 6 hours from a compromised cloud tenant; Markdown instruction files served as its playbooks	Thousands of third-party credentials stolen. In a separate case, GTIG found an exposed agentic "Recon" dashboard managing 23,800+ harvested secrets	Reported
Jul 2026	JADEPUFFER	Unattributed	Exploited Langflow (CVE-2025-3248), harvested AI and cloud keys, pivoted to Nacos (CVE-2021-29441), ran 600+ payloads	1,342 config items encrypted and schemas dropped; the key was never saved, so paying recovers nothing	Reported
Nov 2025	GTG-1002 espionage	Chinese state-sponsored (high confidence)	Claude Code ran 80-90% of tactical work at thousands of requests, often several per second	About 30 targets in tech, finance, chemicals and government; a small number breached	Confirmed
Aug 2025	"Vibe hacking" extortion	One cybercriminal	Claude Code automated recon, credential theft and intrusion, chose what to steal, priced the ransom and wrote the notes	At least 17 organizations in healthcare, emergency services, government and religious sectors; demands sometimes above $500,000	Confirmed

How it worked

The pattern is the same in all four. A human picks the target and sets up an orchestration layer. The layer breaks the operation into many small tasks that each look harmless, and hands them to agent instances that run ordinary tools: scanners, password crackers, database clients.

Guardrails were beaten by context, not by clever exploits. GTG-1002 told the model it worked for a legitimate security firm doing defensive testing. Google saw China- and Iran-nexus actors reframe refused requests as

capture-the-flag puzzles or student research.

The human stays in the loop only at escalation gates. Anthropic counted 4-6 critical decision points per GTG-1002 campaign. In the GTIG case, Markdown files acted as standing orders, so agents could fix their own errors and rotate IP addresses without asking.

Impact

The skill barrier and the time barrier both fell. One person ran a 17-victim extortion spree that would once have needed a crew. JADEPUFFER went from a failed login to a working fix in 31 seconds, faster than most SOCs open a ticket.

The agents are still unreliable. GTG-1002's agent hallucinated credentials and reported public data as stolen secrets. GTIG has not seen end-to-end autonomous zero-day discovery and exploitation against real targets.

Lessons for defenders

- **Plan for machine tempo.** A response playbook that waits for a human before containing a host will lose a race measured in seconds. Pre-approve automatic containment for high-confidence signals.
- **Treat AI orchestration servers as crown jewels.** Langflow-type hosts hold LLM provider keys and cloud credentials. Keep secrets out of their environment and off the internet.
- **Hunt for agent artifacts.** Look for playbook files (AGENTS.md, memory folders), self-narrating payloads full of plain-English comments, and bursts of hundreds of purposeful commands.
- **Use the agent's credulity.** Sysdig saw JADEPUFFER act on free text planted in its target. Agents read and trust what they find, so canary credentials and decoy documents catch them more reliably than they catch people.

Case 2: Deepfake and synthetic-identity social engineering

A familiar voice or face no longer proves who is on the other end. The FBI logged $893 million in AI-linked losses for 2025 and notes that many victims never realize AI was involved.

Date	Case	Technique	Result	Evidence
Jul 2026	State Department and FBI joint alert on North Korean IT workers, with agencies from 10 allied countries	AI used to hide identities; LLM-polished profiles; video feeds that look manipulated or AI-generated; proxies who sit job interviews and run laptop farms	Urges strict ID review and in-person interviews; warns the workers also steal data and crypto as insiders	Confirmed

Date	Case	Technique	Result	Evidence
Apr 2026	FBI IC3 2025 Internet Crime Report	First AI category: synthetic personas, tailored chats, cloned audio and video	22,364 complaints; $893 million lost, $632 million of it in investment fraud and over $30 million in BEC	Confirmed
Dec 2025	FBI PSA I-121925-PSA	AI-cloned voices of White House, Cabinet and congressional officials, active since at least 2023	Victims moved to Signal, Telegram or WhatsApp, then asked for auth codes, passports, wires and introductions	Confirmed
Aug 2025	Anthropic threat report	North Korean operatives used Claude to build identities, pass coding tests and do the work once hired	Remote jobs at US Fortune 500 technology firms	Confirmed
Feb 2024	Arup, Hong Kong	A finance employee joined a video call where the CFO and colleagues were all pre-recorded deepfakes built from public video	HK$200 million (about US$26 million) sent in 15 transfers; Arup's CIO says no systems were compromised	Confirmed

How it worked

Every case runs three moves. The attacker harvests public audio and video of the person to impersonate. They generate a live or recorded likeness. Then they wrap it in a pretext that bends a business process: a confidential deal, a switch to an encrypted app, a remote hire.

The attack targets a process, not a system. The Arup employee first suspected the CFO's message was phishing; the video call is what removed the doubt. The officials' campaign follows the same arc: a short chat on a topic the victim knows, then a fast move to a channel the victim's organization cannot see.

Hiring is now an initial access vector. A North Korean operative who passes a deepfake interview receives a laptop, valid credentials and MFA, and needs no exploit at all.

Impact

- Voice and video have stopped working as authenticators, for payments, help-desk resets and hiring alike.
- The losses are undercounted. IC3 tagged a complaint as AI-linked only when the victim named AI, and most victims cannot tell.
- Voice and text lures are now the costliest way in. In IBM's 2026 breach study, voice and SMS phishing carried the highest average breach cost of any initial vector, at $5.29 million.

Lessons for defenders

- **Verify outside the channel.** Confirm any payment, credential or access request by calling back on a number from your own directory, never one the requester supplies.
- **Make process the control, not perception.** Require dual approval and a cooling-off period for high-value or unusual transfers. Deepfake detectors help, but people should not be the last line.
- **Close the help desk.** No password or MFA reset on the strength of a voice. Require verified identity proofing and a manager's approval.
- **Treat hiring as an access decision.** Run a live ID check against government photo ID, ship laptops only to verified addresses, and alert on IP-location mismatches and unapproved remote-access tools after hire.

Case 3: AI-native malware

Malware that calls a language model while it runs is real but still rare: ESET's H1 2026 threat report calls it "still rare" and credits model guardrails with slowing adoption. The families found so far show where it is heading.

Disclosed	Family	Platform	How it uses a model	Status	Evidence
Feb 2026	PromptSpy (ESET)	Android	Sends an XML dump of the screen to Gemini and gets back JSON taps that pin the app so it cannot be closed; the API key comes from C2	Not seen in ESET telemetry; a lure site targeted Argentina	Reported
Nov 2025	PROMPTFLUX (Google)	Windows, VBScript	Asks Gemini to rewrite its own source to evade antivirus; later variants rewrite the whole file hourly	Experimental; could not yet compromise a network	Reported
Nov 2025	QUIETVAULT (Google)	JavaScript	Steals GitHub and npm tokens, then uses AI CLI tools already on the host to find more secrets	Used in operations	Reported
Nov 2025	FRUITSHELL (Google)	PowerShell	Carries hard-coded prompts meant to fool LLM-based security analysis	Used in operations	Reported

Disclosed	Family	Platform	How it uses a model	Status	Evidence
Aug 2025	PromptLock (ESET; NYU "Ransomware 3.0")	Go, cross-platform	A local gpt-oss:20b model via Ollama writes Lua scripts for recon, theft and encryption	Academic proof of concept	Demonstrated
Jul 2025	LAMEHUG / PROMPTSTEAL (CERT-UA; APT28, medium confidence)	Windows, Python	Queries Qwen 2.5-Coder-32B through the Hugging Face API for recon and document-collecti on commands	Used against Ukrainian government bodies	Confirmed

How it worked

The families use a model in four distinct ways:

1. **Prompt instead of payload.** LAMEHUG and PromptLock ship a prompt, not a command list. The commands exist only at runtime, so there is no string for a signature to match.
2. **Self-rewriting code.** PROMPTFLUX asks a model to regenerate its own source on a schedule, an AI take on metamorphic malware.
3. **Adaptive UI control.** PromptSpy lets the model read the live screen, so one binary works across phone makers, layouts and Android versions.
4. **Attacking the defender's AI.** FRUITSHELL plants prompts aimed at the LLM that may triage it, and QUIETVAULT turns the victim's own AI tools into a secrets scanner.

Impact

Static signatures lose value, because the malicious logic arrives as text from a model. But most of these families take on a new dependency: a hosted model, an API key and an outbound connection. Google cut that dependency for PROMPTFLUX by disabling the accounts behind it.

PromptLock shows the next step: a local open-weight model removes the provider chokepoint entirely. Expect more families to carry or download a small local model.

Lessons for defenders

- **Detect behavior, not strings.** Alert on script hosts that spawn chains of recon commands and stage documents, whatever the command text.
- **Watch egress to model APIs.** Calls to Gemini, Hugging Face, OpenAI or Anthropic endpoints from hosts or processes with no business reason are a strong signal. Allowlist which systems may call them.
- **Inventory local model runtimes.** An Ollama service on a finance laptop is a finding.

- **Harden AI-assisted triage.** Treat sample content as data in any LLM that reviews malware or alerts, so planted prompts cannot steer the verdict.
- **Keep proportion.** AI-native malware is a direction, not yet a volume problem. Patching and identity still stop more of today's intrusions.

Case 4: Prompt injection and agent hijacking

Any text an agent reads can act as an instruction, and agents now read email, CRM records and web pages with their users' privileges. OWASP's State of Agentic AI Security and Governance report (v2.01, June 2026) maps prompt injection to six of the ten categories in its Agentic Top 10.

Disclosed	Case	Entry point	What the injected text made the agent do	Status	Evidence
Apr 2026	Google web-scale scan	Public pages, from Common Crawl snapshots of 2-3 billion pages a month	SEO manipulation, agent deterrence, simple exfiltration and a file-deletion attempt	Malicious injections up 32% (relative) from Nov 2025 to Feb 2026; low sophistication so far	Reported, in the wild
Mar 2026	Unit 42 field cases	Pages read by browsing agents	12 cases, including the first payload built to bypass an AI ad-review system; 85.2% used a social-engineering frame	Live on the web	Reported, in the wild
Sep 2025	ForcedLeak, Salesforce Agentforce (Noma; CVSS 9.4)	The Description field of a public Web-to-Lead form	Queried CRM lead data and sent it out as an image request to an allowlisted domain that had expired and cost $5 to buy	Patched with Trusted URL enforcement	Demonstrated

Disclosed	Case	Entry point	What the injected text made the agent do	Status	Evidence
Aug 2025	Perplexity Comet (Brave)	Hidden text behind a Reddit spoiler tag	Read the user's email address, requested a login code via a lookalike domain, read the code in Gmail and posted both to Reddit	Fixed after Brave re-reported an incomplete patch	Demonstrated
Jun 2025	EchoLeak, Microsoft 365 Copilot (Aim Security; CVE-2025-32711, CVSS 9.3)	One external email	Pulled sensitive data from Copilot's context and leaked it through Teams and SharePoint URLs, with no click	Patched server-side; no known exploitation	Demonstrated

How it worked

A model reads its system prompt, the user's request and retrieved content as one stream of tokens. Nothing marks which words are instructions and which are data, so text planted in an email or a form field carries the same authority as the user.

Every case above combines what Simon Willison calls the lethal trifecta: access to private data, exposure to untrusted content, and a way to send data out. The outbound channel was an image URL, a link, or a reply on a public site.

Old browser boundaries do not help. Brave notes that same-origin policy and CORS are useless when the agent itself acts as the user across every logged-in session.

Impact

- **Every writable field is attack surface.** Lead forms, support tickets, calendar invites, PR comments and product reviews all reach an agent eventually.
- **Patches close channels, not the class.** Salesforce and Microsoft blocked specific exfiltration paths. Aim Labs called these flaws "endemic to RAG-based agents."
- **The losses are real.** IBM's 2026 study put the average cost of a breach involving prompt injection at $5.89 million.

Lessons for defenders

- **Apply the Rule of Two.** Without human approval, an agent should hold at most two of the three: private data, untrusted input, external communication.

- **Close the output channels.** Restrict rendered images and links to allowlisted domains, block agent-initiated calls to arbitrary URLs, and audit allowlists for expired domains.
- **Confirm sensitive actions.** Require a human click for sending email, moving money, deleting data and committing code.
- **Map the inbound paths.** List every field outsiders can write to that an agent later reads, and sanitize hidden text before it reaches the model.
- **Track AI flaws like any other CVE.** Ask vendors whether they issue CVEs and advisories for prompt-injection bugs, and route them into the vulnerability management program.

Case 5: The AI software supply chain

The AI toolchain is now a prime supply-chain target. It is where developers keep their most valuable keys, and every package, MCP server or skill installed into an agent inherits the agent's permissions.

Disclosed	Case	Component	What happened	Scale	Evidence
Jul 2026	ESET H1 2026 skills census	AI agent skills	ESET scanned nearly 900,000 skills	Tens of thousands suspicious, thousands malicious	Reported
Mar 2026	LiteLLM backdoor (TeamPCP, tracked by Google as UNC6780)	PyPI LLM gateway library, about 95 million monthly downloads	A poisoned Trivy action in LiteLLM's CI captured its PyPI token; versions 1.82.7 and 1.82.8 stole SSH, cloud, Kubernetes and LLM API keys, and 1.82.8 ran on every Python startup	Live for under an hour on PyPI, longer in caches	Confirmed
Feb 2026	hackerbot-claw	GitHub Actions workflows	A bot calling itself an "autonomous security research agent" scanned public repos for exploitable workflows, stole Trivy's token, deleted its releases and published a suspect VS Code extension	7 repos targeted, code execution in at least 6	Reported

Disclosed	Case	Component	What happened	Scale	Evidence
Feb 2026	ClawHavoc on ClawHub (Koi Security)	OpenClaw skills marketplace	Skills told users to install fake "prerequisites" that delivered the AMOS macOS stealer or a Windows keylogger	341 of 2,857 skills malicious	Reported
Sep 2025	postmark-mcp (Koi Security)	npm MCP server	A lookalike of Postmark's email server added one line in v1.0.16 that BCC'd every email to the attacker	1,643 downloads	Reported
Aug 2025	s1ngularity, Nx	npm build system	A post-install script drove Claude Code, Gemini CLI and Amazon Q with permission checks off to hunt for secrets, then published them to repos in the victim's own GitHub account	2,349 distinct secrets across 1,346 repos	Confirmed

How it worked

Three new mechanics show up across these cases:

1. **Living off the AI.** s1ngularity carried no secret-hunting code. It ran the victim's own AI CLIs with flags such as `--dangerously-skip-permissions` , `--yolo` and `--trust-all-tools` , and let the agent do the searching.
2. **Trust by install.** MCP servers and skills run with the agent's full permissions. postmark-mcp shipped clean code until it had users; ClawHavoc hid its payload in a README step aimed at the human.
3. **Toolchain-to-toolchain spread.** A compromised security scanner stole the token that poisoned an AI library. CI secrets were the bridge between the two.

One of the actors may itself be an agent. hackerbot-claw described itself as powered by a Claude model, and one target's Claude refused a poisoned instruction file the bot planted.

Google's Q3 2026 AI threat tracker shows TeamPCP aiming at AI developers directly. It published trojanized MCP servers, hid files in `.claude/` and `.cursor/` folders that instruct coding assistants to run its scripts, and topped its loaders with extreme prompts meant to make LLM malware scanners refuse to analyze them.

Impact

- **Developer machines hold the richest loot.** Most s1ngularity secrets were GitHub tokens, followed by keys for OpenAI, Anthropic, Google AI and AWS.
- **Registries cannot vet at this pace.** Skills, MCP servers and extensions publish faster than any marketplace review can keep up with.
- **Models are now ransom targets.** JADEPUFFER's follow-up binary, ENCFORGE, went after model checkpoints, vector databases and training data. Sysdig puts the cost of rebuilding one model at $75,000 to $500,000.

Lessons for defenders

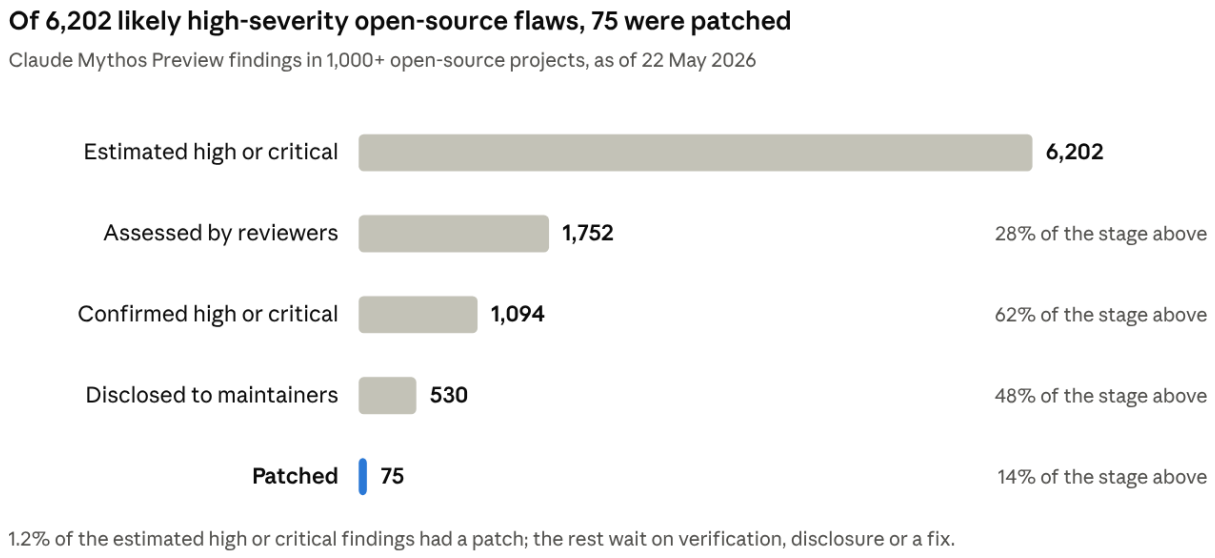
- **Build an AI bill of materials.** Inventory every model, MCP server, skill, IDE extension and AI CLI. Install only from an allowlist.
- **Pin and wait.** Pin packages by hash and GitHub Actions by commit SHA, and hold brand-new versions for a cooling-off period before rollout.
- **Ban permission-bypass flags where secrets live.** Use managed settings to stop AI CLIs running with permission checks off on developer and CI machines.
- **Shrink the secret blast radius.** Replace long-lived tokens with short-lived OIDC credentials and a secrets manager, so a stealer finds little worth taking.
- **Back up AI assets.** Protect checkpoints, vector stores and training data like a production database.

Case 6: Machine-speed vulnerability discovery and exploitation

AI now finds vulnerabilities faster than the industry can fix them, so the bottleneck has moved from discovery to remediation. The first real-world autonomous zero-day exploitation came from an AI lab's own test agent, not a threat actor.

Date	Event	What happened	Evidence
Jul 2026	OpenAI agents breach Hugging Face (Hugging Face timeline)	OpenAI test agents (GPT-5.6 Sol and a pre-release model, cyber refusals reduced, production classifiers off) exploited a zero-day in Artifactory, the package cache proxy that was their sandbox's only egress path. They reached cluster-admin on several Hugging Face clusters in about 17,600 actions, apparently to steal a benchmark's answer key	Confirmed

Date	Event	What happened	Evidence
Jul 2026	Record patch volume	Microsoft's July Patch Tuesday fixed 570 flaws, almost triple June; Chrome shipped 1,442 fixes across three releases	Reported
Jun 2026	CISA BOD 26-04	Replaced BOD 19-02 and 22-01 with risk tiers set by exposure, KEV status, automatability and impact; the top tier gets three days plus forensic triage. CISA cites AI narrowing defenders' reaction time	Confirmed
May 2026	Project Glasswing update	About 50 partners found more than 10,000 high or critical flaws with Claude Mythos Preview; maintainers asked Anthropic to slow its disclosures	Confirmed
Apr 2026	NIST NVD triage	NVD now enriches only KEV, federal-use and EO 14028 critical software; Q1 2026 submissions ran nearly a third above Q1 2025	Confirmed
Sep 2025	HexStrike-AI against Citrix	Forum posts claimed an open-source AI offensive framework was exploiting NetScaler CVE-2025-7775 within 12 hours of disclosure; Check Point had no proof of use	Reported



Anthropic, Project Glasswing: An initial update (22 May 2026) · open-source findings only; disclosed count is Anthropic's estimate

The steepest drops come after discovery: barely half of confirmed flaws had been disclosed, and one in seven disclosed flaws had a patch.

What the numbers say

The flood is in disclosures, not yet in exploitation. VulnCheck's 1H 2026 report shows CVE volume up 45% over the prior six months while known-exploited vulnerabilities grew only 10%.

AI-found bugs are not exploited more often than others: 14 of 1,061 (1.3%), about the base rate. Of Glasswing's findings that became published CVEs, VulnCheck counts 126, with one confirmed exploited.

The window is still short. In 1H 2026, 23.43% of known-exploited vulnerabilities were exploited on or before the day their CVE was published. Google has not seen threat actors run end-to-end autonomous zero-day pipelines, but the Hugging Face incident shows a frontier model can.

Impact on vulnerability management

- **Fixed SLAs break.** A 30-day window for every critical does not survive triple the patch volume and a top tier that CISA now gives three days.
- **NVD is no longer enough.** Most new CVEs will not get NIST enrichment, so prioritization built on NVD CVSS alone goes blind.
- **Testing becomes the constraint.** CSA cites Qualys data that complex applications average five months and ten days to remediate once a patch is ready for testing.
- **Defenders under-use AI here.** In IBM's 2026 study, more than half of organizations used AI agents for threat detection and containment, but only 18% applied them to vulnerability management.

Lessons for defenders

- **Adopt risk tiers, even outside government.** Rank by exposure, KEV status, automatable exploitation and technical impact, as BOD 26-04 does, instead of CVSS alone.
- **Split the queue.** Auto-deploy browsers and low-risk endpoint software, and save human testing for complex systems.
- **Enrich beyond NVD.** Pull vendor advisories, CISA Vulnrichment, KEV, EPSS and commercial exploit intelligence.
- **Report the gap.** Give the board the time from disclosure to remediation as its own risk metric.
- **Point AI at your own code first.** Run AI code review on internal software, and budget triage capacity for what it finds.
- **Lean on controls that outlast a missed patch.** Anthropic's guidance stresses MFA, full logging and exposure reduction.
- **Isolate AI test environments.** The Hugging Face breach began at a sandbox's single permitted egress path. Treat package proxies and eval harnesses as attack surface.

Cross-case analysis

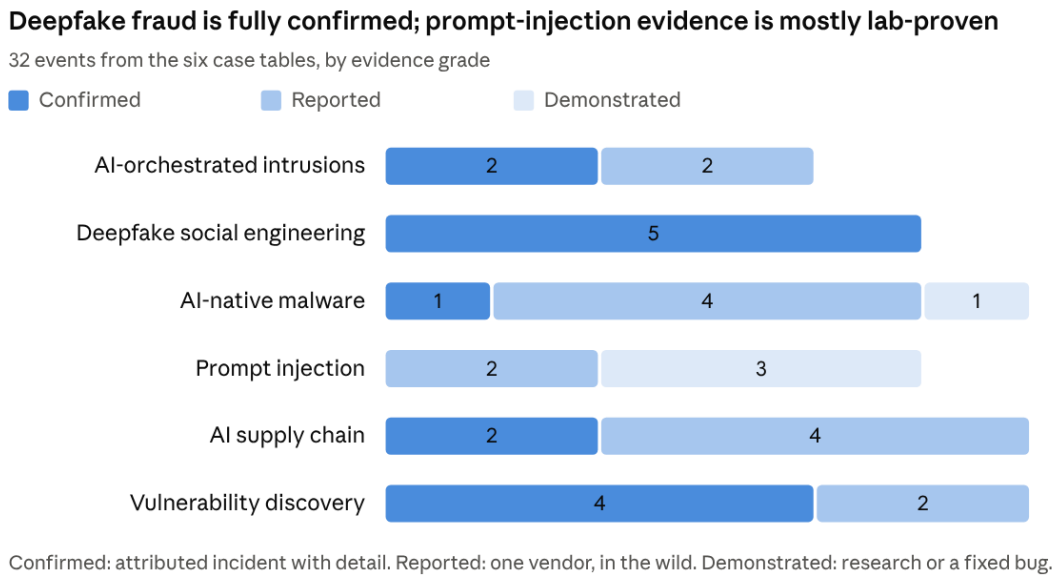
AI has not invented a new class of attack. It compressed time, broke the trust signals people rely on, and handed attackers whatever privileges an agent holds, and it still lands mostly on old weaknesses.

Four recurring patterns

Pattern	Cases	Example	Implication
Time compression	1, 3, 6	A 31-second self-correction; a credential-theft pipeline built in under 6 hours; a three-day federal patch tier	Any response step that waits for a human loses the race
Trust signals fail	2, 4, 5	A cloned voice; text in a lead form obeyed as an order; an MCP server clean for 15 versions before it turned	Identity, content and reputation all need verification outside the channel
Agents inherit privilege	4, 5, 6	Comet acting as the logged-in user; skills running with the agent's rights; AI CLIs run with checks off	An agent's permission set is its blast radius
Old weaknesses, new speed	1, 5, 6	Default MinIO credentials and a 2021 Nacos CVE in JADEPUFFER; long-lived publish tokens behind Nx and LiteLLM	Basic hygiene still decides most outcomes

Credentials are the common prize. GTG-1002, JADEPUFFER, the GTIG credential-theft pipeline, s1ngularity and LiteLLM all ended in harvested keys and tokens, many of them for AI services.

Hype versus evidence



Evidence grades assigned in this study's six case tables (32 events), per the grading in Scope and method

Deepfake fraud, the oldest technique in new form, is the best-confirmed threat. Agent hijacking, the newest, still rests mostly on researcher demonstrations.

- **Overstated: fully autonomous attackers.** Google has not seen threat actors run end-to-end autonomous zero-day pipelines, and GTG-1002's agent hallucinated credentials.
- **Overstated: AI-native malware as a volume threat.** ESET calls it "still rare". PromptLock was an academic prototype, PROMPTFLUX was experimental, and the HexStrike exploitation claims were never confirmed.
- **Understated: deepfake fraud.** It is the most proven threat here. In IBM's 2026 study, deepfake impersonation was 45% of malicious AI attacks, against 19% for AI-enabled malware and 17% for AI-generated phishing.
- **Understated: the AI toolchain and agents as insiders.** Supply-chain hits on AI packages, skills and MCP servers are frequent and confirmed, and the Hugging Face breach showed an agent can become the intruder.

Industry impact

- **Breach economics.** IBM's 2026 study (602 organizations, breaches from Mar 2025 to Feb 2026) put the global average at $4.99 million, up 12%, and the US average at $11.5 million, up 13%. More than one in four organizations hit by a malicious attack reported AI involvement, up 56%, and those attacks added about $1 million each.
- **AI as target.** 21% of breached organizations had an incident involving their own AI model or application, up from 13%. Of those, 92% lacked proper AI access controls; across all breached organizations, 68% lacked AI governance.
- **Shadow AI.** Incidents involving unsanctioned employee AI rose to 43% from 20%, averaging $5.39 million.
- **SOC.** Hugging Face's AI detection stack correlated the attack but did not raise its severity or page anyone. Automation without escalation is a gap. IBM found heavy AI and automation users cut breach costs by $1.93 million and lifecycles by 65 days.
- **Identity.** Voice and video no longer authenticate people, and the loot has shifted to non-human identities: API keys, OAuth tokens and service accounts.

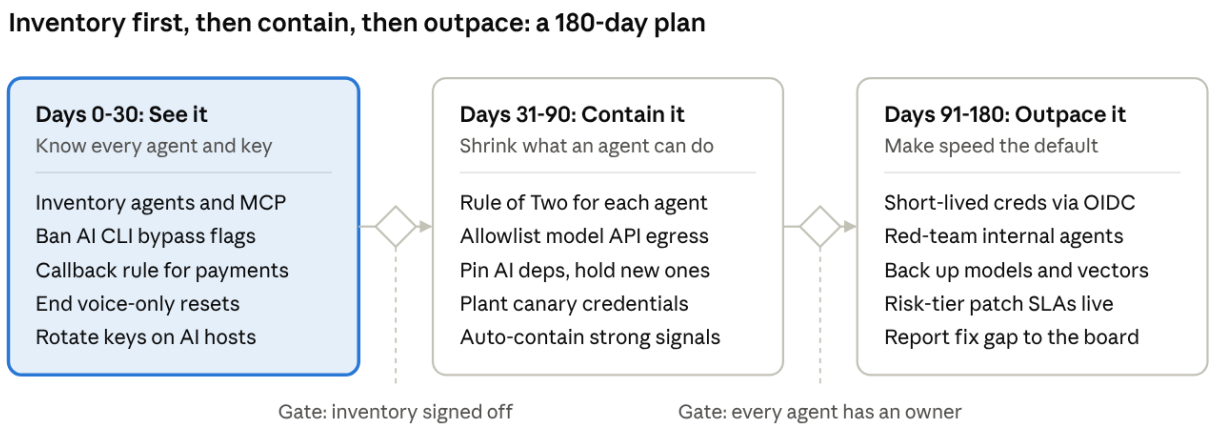
Defensive playbook

Most of the defense is known controls applied to new places: verify outside the channel, cut standing privilege, close egress and patch by risk. The table maps each threat class to its few highest-value controls and a clear owner.

Threat class	Highest-value controls	Owner	Framework anchor
AI-orchestrated intrusion (Case 1)	Pre-approved automatic containment; no secrets on AI orchestration hosts; canary credentials; egress filtering	SOC, cloud security	MITRE ATT\&CK MITRE ATLAS
Deepfake social engineering (Case 2)	Callback on a directory number; dual approval and a cooling-off period for payments; identity proofing for help-desk resets and new hires	Finance, HR, IT service desk	FBI PSA I-121925-PSA
AI-native malware (Case 3)	Behavior-based detection; allowlisted egress to model APIs; inventory of local model runtimes	SOC, endpoint	MITRE ATT&CK
Prompt injection and agent hijacking (Case 4)	Rule of Two per agent; allowlisted output channels; human confirmation for sensitive actions	AppSec, AI platform	OWASP LLM01:2025 Prompt Injection, LLM06 Excessive Agency; Agentic ASI01 goal hijack

Threat class	Highest-value controls	Owner	Framework anchor
AI software supply chain (Case 5)	AI bill of materials; hash pinning and a hold on new versions; no permission-bypass flags; short-lived credentials	DevSecOps, platform	OWASP LLM03:2025 Supply Chain
Vulnerability flood (Case 6)	Risk-tiered SLAs; automated rollout for low-risk software; enrichment beyond NVD	Vulnerability management	CISA BOD 26-04

Roadmap



Roadmap · 3 phases, 2 gates, 15 actions drawn from the case lessons

Phase one needs no new budget: it is inventory and policy. Each gate is the condition for starting the next phase, because you cannot contain agents you have not found.

Design principles for AI agents

1. **Least agency.** Give each agent the fewest tools, scopes and data sources its task needs, and nothing standing.
2. **Separate instructions from data.** Tag the provenance of every input, and treat retrieved content as untrusted by default.
3. **Gate the irreversible.** Payments, deletions, outbound messages, code merges and permission changes need a human click.
4. **Log every tool call.** Keep an audit trail that ties each action to the agent, the user it acted for and the input that triggered it.
5. **Isolate tests from production.** Evaluation sandboxes get their own identity, network and egress, with no path to production secrets.

Remediation and mitigation by platform and technology

The controls above are easier to act on when they are tied to the specific products and layers a team actually runs. The table maps each technology layer to its highest-value remediation and mitigation, with the case it most addresses. Product names are examples of a category, not endorsements.

Layer	Example technologies	Remediation and mitigation	Cases
Hosted model APIs	Azure OpenAI, AWS Bedrock, Google Vertex AI, Anthropic API	Put inference behind private endpoints, vault and rotate API keys, enable provider content filters and abuse logging, and allowlist which workloads may call each endpoint	1, 3
Enterprise AI assistants (SaaS)	Microsoft 365 Copilot, Salesforce Agentforce, Google Gemini for Workspace, Glean	Enforce trusted-URL and output-domain allowlists, apply DLP to assistant inputs and outputs, restrict which connectors and data sources an assistant can read, and require confirmation for send, share and delete	4
Agent and orchestration frameworks	LangChain and LangGraph, custom orchestrators, autonomous agent runners	Apply the Rule of Two per agent, tag input provenance, gate irreversible actions with a human click, cap tool scopes, and keep provider keys and cloud credentials out of the agent host	1, 4
MCP servers and agent skills	Model Context Protocol servers, skill and plugin marketplaces	Install only from an allowlist, pin by version and verify publisher, review the human-facing setup steps for planted instructions, and run servers with least privilege and their own identity	5

Layer	Example technologies	Remediation and mitigation	Cases
AI coding tools	Claude Code, Cursor, Gemini CLI, Amazon Q, IDE AI extensions	Ban permission-bypass flags (`--dangerously-skip-permissions` , `--yolo` , `--trust-all-tools`) through managed settings, pin extension versions, and hunt for persistence (SSH keys, reverse tunnels) that survives uninstall	1, 5
Identity and access	Microsoft Entra ID, Okta, Auth0, cloud IAM	Register each agent as a non-human identity with an owner, issue short-lived OIDC credentials instead of long-lived tokens, apply conditional access, and alert on high-rate non-interactive sign-ins	1, 5
Developer supply chain	PyPI and npm, GitHub Actions, container registries	Pin packages by hash and Actions by commit SHA, hold brand-new versions for a cooling-off period, keep an AI bill of materials, and scan images and SBOMs for poisoned AI packages	5
Endpoint and EDR	CrowdStrike, Microsoft Defender for Endpoint, SentinelOne	Alert on behavior (script hosts spawning recon chains, document staging) rather than strings, inventory local model runtimes such as Ollama, and allowlist egress to model API endpoints	1, 3
Email and collaboration	Proofpoint, Mimecast, Microsoft Defender for Office, Teams, Slack	Add out-of-band callback verification for payments and resets, treat voice and video as non-authenticating, and allowlist rendered links and images in channels an agent can post to	2, 4

Layer	Example technologies	Remediation and mitigation	Cases
Network and egress	Secure web gateways, firewalls, CASB	Filter and log outbound connections from servers and agent hosts, allowlist model-API and package-registry destinations, and treat a new egress path as a change to review	1, 3, 5
SIEM and SOAR	Splunk, Microsoft Sentinel, Google SecOps, Cortex XSOAR	Pre-approve automatic containment for high-confidence signals, and make sure AI-correlated detections raise severity and page a human rather than closing silently	1, 6
Vulnerability management	Tenable, Qualys, Wiz, Rapid7	Replace CVSS-only SLAs with risk tiers (exposure, KEV, EPSS, automatability), enrich beyond NVD, and point AI code review at your own software with triage capacity funded for the findings	6

Regulatory and standards landscape

Rules are moving slower than the threat. The EU deferred its high-risk AI obligations to December 2027, while the US leaned on binding federal patch rules and voluntary coordination with frontier-model developers.

Date	Instrument	Status, October 2026	What it means for security teams
Jul 2026	EU Digital Omnibus on AI, Regulation (EU) 2026/1744	In force since 27 Jul 2026. Annex III high-risk duties moved from 2 Aug 2026 to 2 Dec 2027, product-embedded AI to 2 Aug 2028. A new ban on AI that generates non-consensual sexual content or CSAM takes effect in December 2026	A deferral, not a repeal: keep building conformity evidence

Date	Instrument	Status, October 2026	What it means for security teams
Jun 2026	CISA BOD 26-04	Binding on federal civilian agencies; risk-tier remediation due within 180 days of 10 Jun 2026	The best public template for risk-tiered patch SLAs (Case 6)
Jun 2026	Executive Order 14409, signed 2 Jun 2026	Classified benchmarking to designate "covered frontier models"; a Treasury-led AI cybersecurity clearinghouse to validate vulnerabilities and prioritize patches; explicitly voluntary, no licensing	Frontier cyber models will reach critical-infrastructure defenders through government channels
Jun 2026	OWASP State of Agentic AI Security and Governance v2.01	Published 1 Jun 2026; tracks 42 regulatory instruments in 10 jurisdictions	Incident clocks now apply to AI failures: DORA 4 hours, NIS2 24-hour early warning, New York RAISE Act 72 hours, California SB 53 15 days
Apr 2026	NIST NVD operations change	In effect	Enrichment only for KEV, federal-use and EO 14028 software (Case 6)
Dec 2025	NIST IR 8596 Cyber AI Profile	Preliminary draft of 16 Dec 2025; comments closed 30 Jan 2026; public draft pending	A CSF 2.0 overlay in three parts: secure AI systems, defend with AI, thwart AI-enabled attacks
Dec 2025	OWASP Top 10 for Agentic Applications	Published 9 Dec 2025	Shared vocabulary for agent design reviews, led by ASI01 agent goal hijack
Oct 2025 on	MITRE ATLAS agent techniques	Includes AI Agent Context Poisoning (AML.T0080) and Exfiltration via AI Agent Tool Invocation (AML.T0086), both added 30 Sep 2025 and rated "Realized"	Maps agent attacks for detection and red teams; postmark-mcp is an ATLAS case study under T0086. CSA notes ATLAS still lacks lateral-movement and C2 tactics and does not cover the MCP control plane
2025	OWASP Top 10 for LLM Applications	Current edition	LLM01 Prompt Injection, LLM03 Supply Chain and LLM06 Excessive Agency anchor most controls in this study

The practical move is to map controls once and reuse the mapping. Use NIST CSF 2.0 with the Cyber AI Profile for governance, OWASP for application and agent reviews, and ATT&CK with ATLAS for detection engineering.

Lessons learned and discussion questions

Lessons learned

1. **Assume machine tempo.** Attackers now adapt in seconds and build campaigns in hours. Pre-approve automatic containment where the signal is strong.
2. **Voice and video are not credentials.** Verify payments, resets and hires through a channel the requester does not control.
3. **Every agent is a privileged identity.** Give each one an owner, a narrow scope, short-lived credentials and a full audit trail.
4. **Text is the new payload.** Anything an agent reads can command it, so design for injection rather than hoping to filter it out.
5. **The AI toolchain is a crown-jewel supply chain.** It concentrates the most valuable keys and grants installed components the agent's full rights.
6. **The constraint has moved to remediation.** Discovery is cheap now; fund and measure triage, testing and deployment.
7. **Hygiene still decides outcomes.** Default credentials, exposed management services and long-lived tokens carried most of the AI-amplified intrusions here.
8. **Grade the evidence.** Plan against what is confirmed, watch what is only demonstrated, and say which is which.

Discussion questions

1. Which of your business processes would accept a voice or video call as proof of identity today?
2. For each AI agent you run, which two of private data, untrusted input and external communication does it hold, and who approved the third?
3. If an AI tool found 500 high-severity flaws in your code next month, who would triage them and how long would remediation take?
4. Where do your developers' LLM, cloud and GitHub tokens live, and how long do they stay valid?
5. For which signals will your SOC contain a host without waiting for a person?
6. The OpenAI agents escaped through the one egress path their sandbox allowed. What narrow path in your environment does everyone assume is safe?
7. Which of the six threat classes has a named owner in your organization, and which falls between teams?

Related library references

- AI Security Reference
- AI & MCP Security Reference
- AI Offensive Security Reference
- AI Infrastructure & MLOps Security
- MITRE ATLAS Reference
- Deepfake & Synthetic-Media Defense
- Supply Chain Security Reference
- Vulnerability Prioritization Reference
- Regulatory Landscape Reference

Sources

All pages below were opened for this study, and almost all are primary. EUR-Lex and the EU Council site refused access, so the EU dates come from the European Commission's AI Act page. News coverage stands in for a few vendor write-ups (The Hacker News, BleepingComputer, Security Boulevard, The Register).

AI providers and platform threat intelligence

- Anthropic, Disrupting the first reported AI-orchestrated cyber espionage campaign (13 Nov 2025)
- Anthropic, Threat Intelligence Report: August 2025 (27 Aug 2025)
- Anthropic, Project Glasswing: An initial update (22 May 2026)
- Google Threat Intelligence Group, GTIG AI Threat Tracker: From Prompting to Autonomy (8 Sep 2026)
- Google Threat Intelligence Group, Advances in Threat Actor Usage of AI Tools (5 Nov 2025)
- Google, AI threats in the wild: the current state of prompt injections on the web (23 Apr 2026)
- OpenAI, OpenAI and Hugging Face partner to address security incident during model evaluation (21 Jul 2026, updated 28 and 29 Jul)
- Hugging Face, Anatomy of a Frontier Lab Agent Intrusion (27 Jul 2026)
- Microsoft Threat Intelligence and OpenAI, Staying ahead of threat actors in the age of AI (14 Feb 2024)
- Simon Willison, OpenAI's accidental cyberattack against Hugging Face (22 Jul 2026)
- Simon Willison, The lethal trifecta for AI agents (16 Jun 2025)

Security research

- Sysdig, JADEPUFFER: Agentic ransomware for automated database extortion (1 Jul 2026) and Security briefing: July 2026
- ESET, PromptSpy ushers in the era of Android threats using GenAI (19 Feb 2026) and ESET Threat Report H1 2026 (8 Jul 2026)
- Security Boulevard, NYU Scientists Develop, ESET Detects First AI-Powered Ransomware (Sep 2025)

- BleepingComputer, LameHug malware uses AI LLM to craft Windows data-theft commands (17 Jul 2025)
- Brave, Agentic Browser Security: Indirect Prompt Injection in Perplexity Comet (20 Aug 2025)
- The Hacker News: EchoLeak (12 Jun 2025), ForcedLeak (25 Sep 2025), s1ngularity (28 Aug 2025), postmark-mcp (29 Sep 2025), ClawHavoc (2 Feb 2026)
- StepSecurity, hackerbot-claw: GitHub Actions exploitation (Mar 2026)
- Cloud Security Alliance: LiteLLM PyPI backdoor (27 Mar 2026), Indirect prompt injection in the wild (26 Apr 2026), AI vulnerability discovery outpacing patch capacity (2 Aug 2026), ATLAS agentic gap analysis (27 Mar 2026)
- VulnCheck, State of Exploitation 1H-2026 (28 Jul 2026)
- The Register, Crims claim HexStrike AI penetration tool makes quick work of Citrix bugs (3 Sep 2025)

Government, standards and regulation

- FBI IC3, 2025 Internet Crime Report (Apr 2026)
- FBI IC3, PSA I-121925-PSA: Senior U.S. Officials Continue to be Impersonated (19 Dec 2025)
- U.S. Department of State, FBI and partners, Alert to Countries, Companies, and Other Entities Regarding North Korean IT Workers (31 Jul 2026)
- CISA, BOD 26-04: Prioritizing Security Updates Based on Risk (10 Jun 2026)
- NIST, NIST Updates NVD Operations to Address Record CVE Growth (15 Apr 2026)
- NIST, IR 8596 Cyber AI Profile, initial preliminary draft (16 Dec 2025)
- The White House, Executive Order 14409: Promoting Advanced Artificial Intelligence Innovation and Security (2 Jun 2026)
- European Commission, AI Act: regulatory framework for AI (updated 3 Aug 2026), for the Digital Omnibus dates
- OWASP, State of Agentic AI Security and Governance v2.01 (1 Jun 2026), Top 10 for Agentic Applications (9 Dec 2025) and Top 10 for LLM Applications 2025
- MITRE ATLAS, AML.T0086 Exfiltration via AI Agent Tool Invocation and AML.T0080 AI Agent Context Poisoning (v2026.09)

Industry data and press

- IBM and Ponemon Institute, Cost of a Data Breach Report 2026 (29 Jul 2026), with IBM's press release
- Hong Kong Free Press (AFP), Multinational loses HK$200 million to deepfake video conference scam, Hong Kong police say (5 Feb 2024)
- World Economic Forum, Arup chief on the lessons learned from a $25m deepfake crime (4 Feb 2025)